

Cookie SameSite 弱掃複驗佐證說明

對象：aaca.ntua.edu.tw

建立日期：2026-09-07

目的：整理 AppScan 報告與實際 Runtime 複驗證據，作為「Cookie with Insecure or Improper or Missing SameSite attribute」之佐證文件。

摘要結論

- 弱掃項目：DAST: Cookie with Insecure or Improper or Missing SameSite attribute
- AppScan 報告標示 Cookie：rtid、wcms.visitor
- 正式站 Runtime 複驗結果：兩者皆可於實際回應中觀察到 Set-Cookie，且屬性包含 secure、samesite=strict、httponly。
- 目前判斷：正式站 Runtime 未重現 SameSite 缺失；屬高度疑似 False Positive / Scanner Evidence Issue。
- 保留事項：若需最終正式定性，仍建議弱掃執行單位提供該 Finding 當時的原始 Response Set-Cookie Header。

複驗方法

- 以 Chrome DevTools Network / Application 觀察正式站回應與 Browser Cookie 儲存資訊。
- 驗證 Login 流程：POST /Service/Auth/Login。
- 驗證 Refresh 流程：POST /Service/Auth/Refresh。
- 驗證訪客 Cookie 流程：POST /Service/SiteViewCount/TryCountSiteView。
- 交叉比對 AppScan 報告第 8 至 9 頁之 Finding 截圖。
- 本文件所有 Cookie / Token 實值均已遮罩。

以下整理使用者提供之 AppScan Report 截圖。可確認 Finding 名稱與被標示的 Cookie 名稱，但從現有截圖本身，尚不足以直接看到該 Finding 判定時所依據的原始 Response Set-Cookie。

AppScan Finding (rtid)	
M	DAST: Cookie with Insecure or Improper or Missing SameSite attribute 2
How to Fix: Cookie with Insecure or Improper or Missing SameSite attribute	
Issue 1 of 2	
Issue ID:	b101443e-f36b-1410-89cd-00f37f576f24
Severity:	Medium
Status	Open
Location	https://aaca.ntua.edu.tw/
Domain	aaca.ntua.edu.tw
Element	rtid (Cookie)
Path	/
Scheme	https
Domain	aaca.ntua.edu.tw
CVSS	4.7

說明：目前截圖可確認報告項目，但不足以直接看到判定依據的原始 Response Set-Cookie。

```
HTTP/1.1 403 Forbidden
Cache-Control: no-store, must-revalidate, proxy-revalidate, no-cache
Pragma: no-cache
Vary: Origin, Accept-Encoding
Access-Control-Allow-Credentials: true
Access-Control-Allow-Origin: https://aaca.ntua.edu.tr
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Referrer-Policy: strict-origin-when-cross-origin
permissions-policy: geolocation=(), microphone=(), camera=(), fullscreen=(self)
cross-origin-opener-policy: same-origin
```

Issue 2 of 2	
Issue ID:	4ffd433e-f36b-1410-89cd-00f37f576f24
Severity:	Medium
Status	Open
Location	https://aaca.ntua.edu.tw/
Domain	aaca.ntua.edu.tw
Element	wcms.visitor (Cookie)
Path	/
Scheme	https
Domain	aaca.ntua.edu.tw
CVSS	4.7
Date Created	Thursday, August 27, 2026
Last Updated	Thursday, August 27, 2026

說明：目前截圖同樣不足以直接證明掃描器當時看到的原始 Set-Cookie 內容。

```
Content-Length: 16
{
  "SiteIndex": ""
}

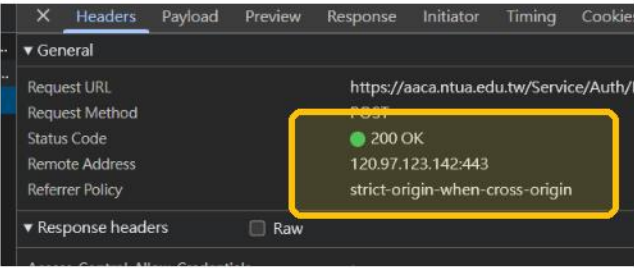
HTTP/1.1 403 Forbidden
Cache-Control: no-store, must-revalidate, proxy-revalidate, no-cache
Pragma: no-cache
Vary: Origin, Accept-Encoding
Access-Control-Allow-Credentials: true
Access-Control-Allow-Origin: https://aaca.ntua.edu.tw
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Referrer-Policy: strict-origin-when-cross-origin
permissions-policy: geolocation=(), microphone=(), camera=(), fullscreen=(self)
cross-origin-embedder-policy: same-origin
cross-origin-embedder-policy: require-corp
cross-origin-resource-policy: same-origin
x-permitted-cross-domain-policies: none
Content-Security-Policy: default-src 'none'; object-src 'none'; base-uri 'none'; frame-ancestors 'none'; form-action 'none'
Strict-Transport-Security: max-age=16070400; includeSubDomains
X-Powered-By:
Date: Mon, 31 Aug 2026 01:58:08 GMT
Content-Type: text/html
Expires: 0
Content-Length: 1215
```

二、Runtime 複驗證據－rtid

下列證據顯示，在正式站實際流程中，rtid 於 Login 與 Refresh 回應中均以 Set-Cookie 發送，且具有 secure、samesite=strict、httponly 屬性。

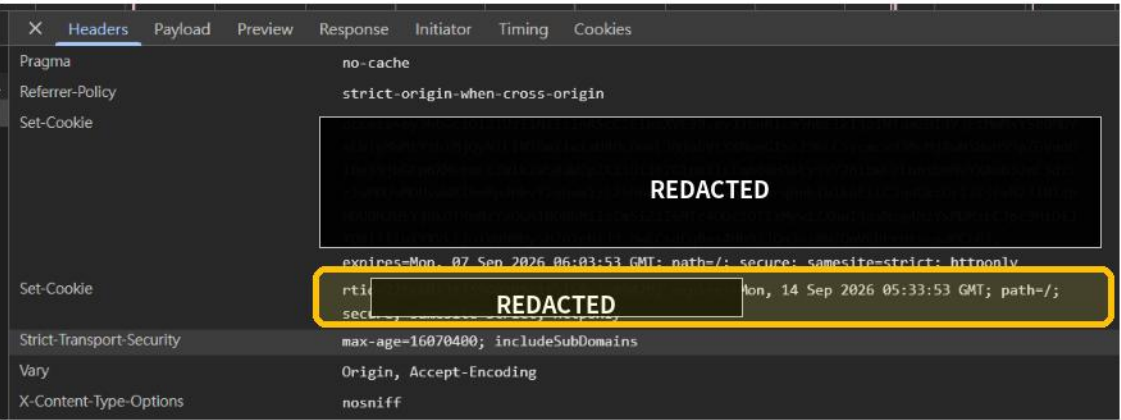
證據 E3：Login 流程 Runtime 驗證

Runtime 驗證：Login 請求



- Request URL：/Service/Auth/Login
- Request Method：POST；Status Code：200 OK

Runtime 驗證：Login 回應 Set-Cookie

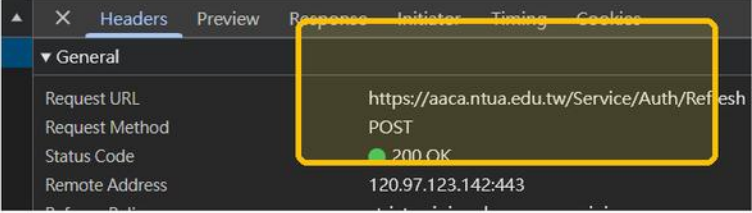


- 可見 rtid 的 Set-Cookie。
- 屬性為 path=/；secure；samesite=strict；httponly。

說明：Cookie / Token 實值已遮罩。

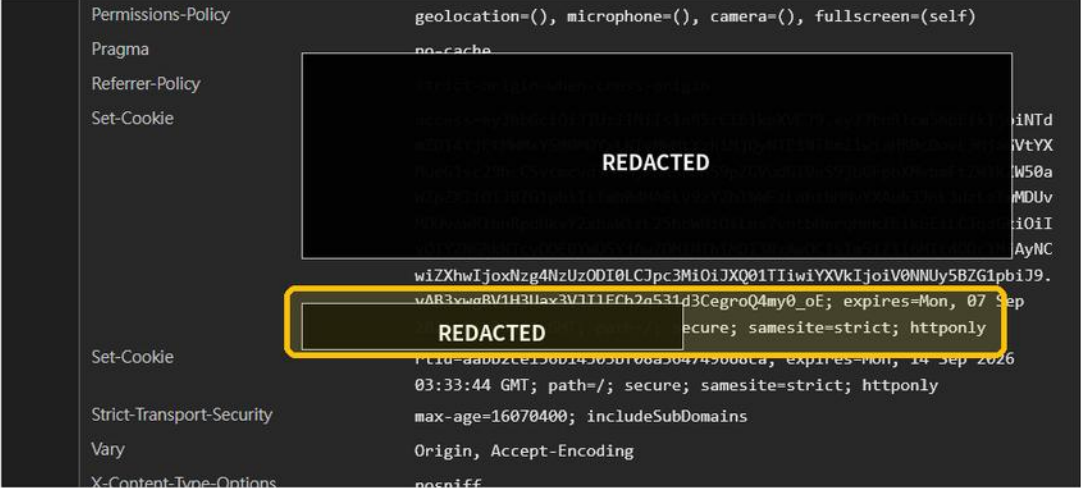
證據 E4：Refresh 流程 Runtime 驗證

Runtime 驗證：Refresh 請求



- Request URL：/Service/Auth/Refresh
- Request Method：POST；Status Code：200 OK

Runtime 驗證：Refresh 回應 Set-Cookie



- Refresh 回應同樣重新發送 rtid 的 Set-Cookie。
- 屬性為 path=/；secure；samesite=strict；httponly。

說明：此證據顯示 rtid 並非僅在單一路徑具備安全屬性。

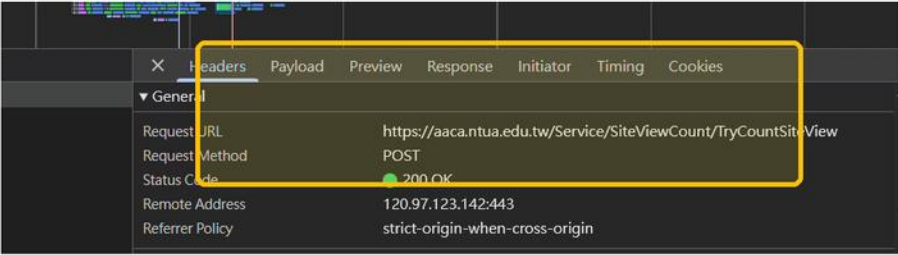
三、Runtime 複驗證據－wcms.visitor

下列證據顯示，wcms.visitor 於 /Service/SiteViewCount/TryCountSiteView 回應中以 Set-Cookie 發送，並且 Browser 端 Cookie Table 可交叉確認 SameSite=Strict、Secure、HttpOnly。

證據 E5：wcms.visitor Runtime 驗證

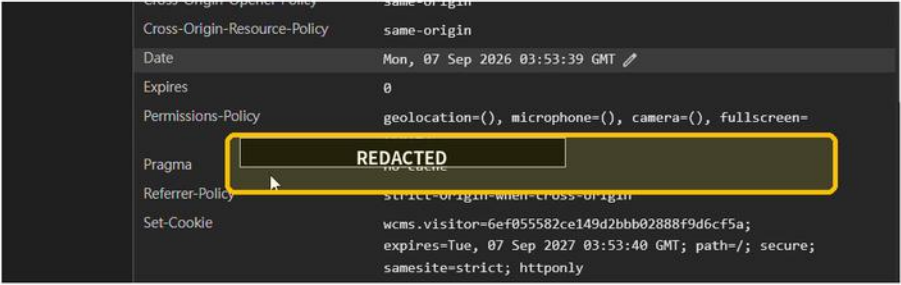
Visitor Cookie Runtime 驗證（上）

Runtime 驗證：SiteView 請求



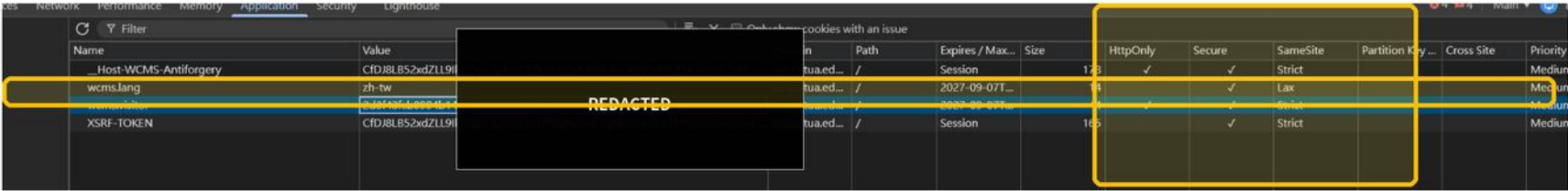
- Request URL：/Service/SiteViewCount/TryCountSiteView
- Request Method：POST；Status Code：200 OK

Runtime 驗證：SiteView 回應 Set-Cookie



- 可見 wcms.visitor 的 Set-Cookie。
- 屬性為 path=/；secure；samesite=strict；httponly。

Application > Cookies 驗證



- Browser Cookie Table 中可見 wcms.visitor。
- 欄位顯示 HttpOnly、Secure、SameSite=Strict。

說明：除 Response Set-Cookie 外，Browser 端 Application > Cookies 也可交叉確認屬性。

四、分析與結論

- AppScan 報告可確認其將 rtid 與 wcms.visitor 兩個 Cookie 判定為「Cookie with Insecure or Improper or Missing SameSite attribute」，Severity 為 Medium。
- 然而，從目前提供的 AppScan 證據截圖來看，畫面中呈現的回應區塊為 403 Forbidden，且未直接展示被判定用的原始 Response Set-Cookie 標頭，因此僅憑目前截圖，無法直接確認掃描器當時究竟看到了哪一筆回應內容。
- 另一方面，正式站 Runtime 驗證已直接觀察到：rtid 於 Login 與 Refresh 回應中皆以 Set-Cookie 發送，且屬性包含 path=/、secure、samesite=strict、httponly；wcms.visitor 亦可於 SiteView 回應及 Browser Cookie Table 中確認具備相同安全屬性。
- 因此，以目前可取得的證據判斷，正式站 Runtime 無法重現該 SameSite 缺失。此 Finding 屬高度疑似 False Positive / Scanner Evidence Issue。
- 若要進一步完成正式結案，建議請弱掃執行單位提供該 Finding 產生當時的原始 HTTP Request / Response（至少需含原始 Response Set-Cookie Header）、掃描時間點、對應 URL 與 Rule Evidence，以便最終確認是否為誤判。

建議對外回覆重點

- 已依正式站實際流程完成 Runtime 複驗。
- rtid 與 wcms.visitor 之 Set-Cookie 皆已確認具備 secure、samesite=strict、httponly。
- 目前正式站無法重現 SameSite 缺失。
- 請協助提供弱掃原始 Finding Evidence（特別是原始 Response Set-Cookie Header），以利最終判定是否屬 False Positive / Scanner Evidence Issue。